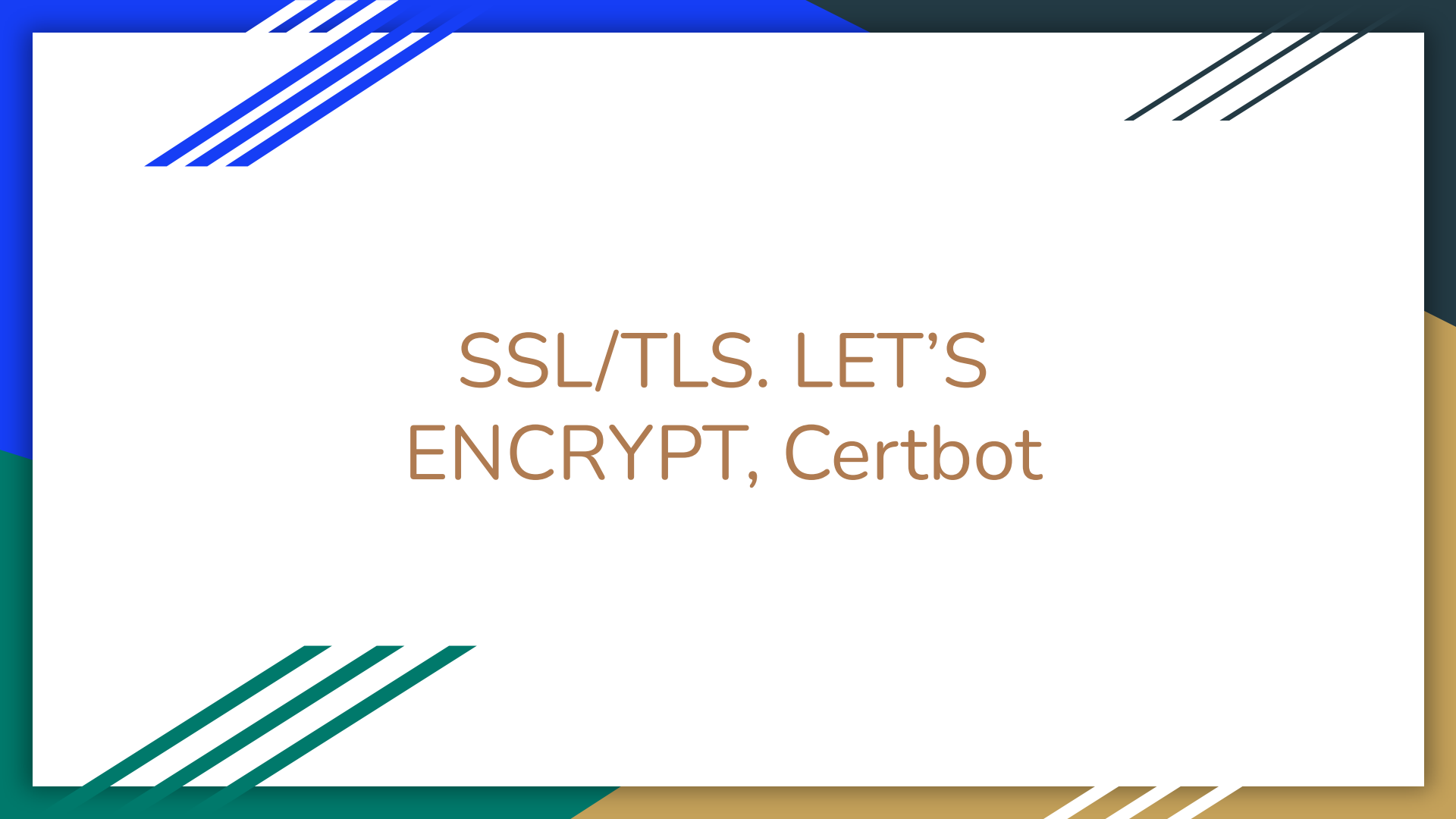




SSL/TLS. LET'S
ENCRYPT, Certbot



ЩО TAKE HTTPS

ПРОТОКОЛ HTTP + БЕЗПЕКА

- SSL/TLS (рівень захищених сокетів/безпека транспортного рівня)
- зберігає ваші паролі, комунікації та дані кредитної картки в безпеці між вашим комп'ютером і серверами, з якими ви спілкуєтесь на іншому боці.
- все ще розмовляє через HTTP, але зв'язок шифрується та розшифровується

ЯК ЦЕ ПРАЦЮЄ?

ПРИВІТАННЯ —> ОБМІН СЕРТИФІКАТАМИ —> ОБМІН КЛЮЧАМИ

1. Повідомлення ClientHello

- відомості, які потрібні серверу для підключення до клієнта через SSL
- сервер відповість ServerHello, тобто подібну інформацію, включаючи набір шифрів і версію SSL, які будуть використовуватися

2. Обмін сертифікатами

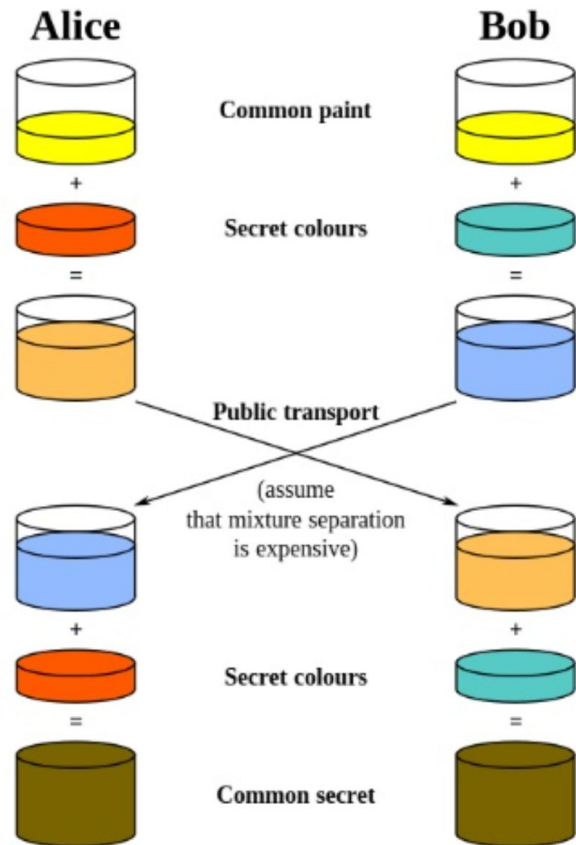
- сервер повинен підтвердити свою ідентичність за допомогою свого SSL-сертифікату*
- чи (а) неявно довіряє, чи (б) перевірено одним із багатьох ЦС

3. Обмін ключами

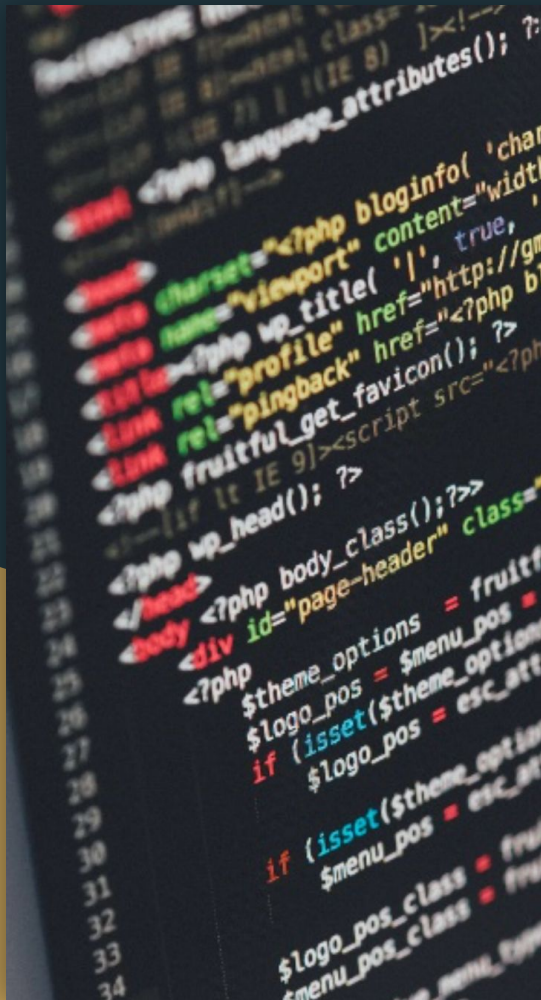
- Шифрування за допомогою симетричного алгоритму з використанням одного ключа
* клієнту також може знадобитися підтвердити свою особу, але не завжди

У ЧОМУ СЕНС?

- HTTP-запити та відповіді тепер можна надсилати через зашифроване текстове повідомлення
- тобто перевіряє, що ви спілкуєтеся безпосередньо з сервером, з яким, на вашу думку, ви спілкуєтесь
- Але оскільки лише інша сторона знає, як розшифрувати це повідомлення, зломисники Man In The Middle не можуть прочитати або змінити будь-які запити, які вони можуть перехопити.
- тобто гарантує, що лише цей сервер може читати те, що ви надсилаєте, і лише ви можете читати те, що він надсилає



Diffie-Hellman Key Exchange



Хоча маленький зелений замочок і літери «HTTPS» у вашому адресному рядку не означають, що у вас і у сайту, який ви переглядаєте, немає достатньо можливостей «повісити себе» в іншому місці, вони принаймні допомагають вам спілкуватися безпечно, поки ви це робите

Rob Heaton

ЗНАЧЕННЯ SSL

- якщо ви бачите зашифрований трафік сьогодні, ви можете припустити, що причина є.
- шифруючи все, ви надаєте прикриття тим, хто цього потребує
- наприклад політичні дисиденти

ЯК ПРАЦЮЄ SSL?

ЧОМУ ВІН ЗАХИЩАЄ КОНФІДЕНЦІЙНУ ІНФОРМАЦІЮ?

1. 2 ключа шифрування

- приватний ключ і відкритий ключ погоджують ключ для цього обміну
- симетричний алгоритм з асиметричним шифруванням
- будь-хто може зашифрувати за допомогою відкритого ключа, але лише сервер може розшифрувати за допомогою закритого ключа

2. цифровий підпис «підписано» іншим органом

3. самопідписання

ЩО ТАКЕ «LET'S ENCRYPT»?

НАЛАШТУВАННЯ СЕРТИФІКАТУ ПЕРЕВІРКИ ДОМЕНУ (DV)*

1. Завантажте Let's Encrypt на свій сервер з адресою www.letsencrypt.org:

```
sudo apt-get install lets-encrypt
```

2. Ви запускаєте його як sudo, повідомляючи йому, що хочете отримати сертифікат для свого домену

```
lets-encrypt oohshinywebsite.com
```

* DV Certificate = «ЦС перевіряє право заявника на використання певного доменного імені. Жодна інформація про компанію не перевіряється, і жодна інформація не відображається, окрім інформації шифрування в межах Secure Site Seal». Існують інші типи сертифікатів із різними вимогами.

ТОЖ... ЯК ЗАШИФРУВАТИ СВІЙ САЙТ?

СПІЛЬНИЙ ХОСТИНГ

- Bluehost
- GoDaddy
- Pantheon
- LiteSpeed
- SiteGround
- Media Temple
- Flywheel
- WP Engine
- DreamHost
- LE's community list

VPS ТА ІНШІ НАЛАШТУВАННЯ СЕРВЕРА

- **nginx** - <https://www.digitalocean.com/community/tutorials/how-to-secure-nginx-with-let-s-encrypt-on-ubuntu-14-04>
- **Apache** - <https://www.digitalocean.com/community/tutorials/how-to-secure-apache-with-let-s-encrypt-on-ubuntu-14-04>
- **Centos vs Debian/Ubuntu** - <https://www.linode.com/docs/security/ssl/install-lets-encrypt-to-create-ssl-certificates>

ЗАГАЛЬНІ ПРОБЛЕМИ

ПОГАНО

- Без підстановочних знаків, тобто складно в багатосерверному або балансованому навантаженні середовищі
- Оновлення кожні 90 днів

ДОБРЕ

- Легко налаштувати
- Безкоштовне використання
- Добре підходить для налаштування одного сервера

ЗАГАЛЬНІ ПРОБЛЕМИ

ПОШИРЕНІ ПРОБЛЕМИ JETPACK

- змінити налаштування WordPress
- Dashboard > Settings > General
- site URL
- WordPress URL

GOOGLE SEO

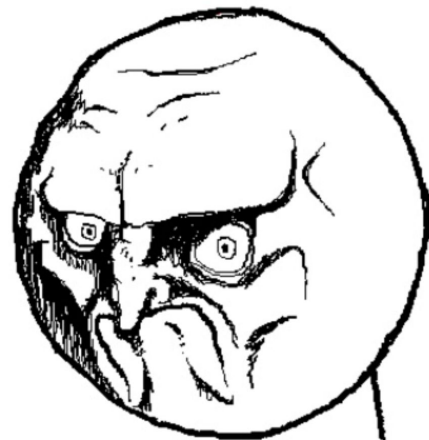
- Ваші позиції в пошуковій видачі проти хоча б мінімальної турботи про вашу аудиторію



Давайте зашифруємо!

Замовлення/оновлення сертифікатів SSL на даний момент

- Згенерувати ключ RSA
- Згенерувати CSR
- Увійдіть у жахливий веб-інтерфейс СА
- Заповніть форму замовлення сертифіката
- Заплатіть багато грошей
- Підтвердіть домен



Давайте зашифруємо

<https://letsencrypt.org/>

- «безкоштовний, автоматизований і відкритий центр сертифікації (CA), що працює на користь суспільства» [<https://letsencrypt.org/about/>]
- Надано ISRG - Дослідницька група безпеки в Інтернеті (некомерційна організація зі штату Каліфорнія)
- Спонсор Mozilla, Akamai, Cisco, EFF, OVH, Facebook, Chrome тощо.
- **Місія:** зменшити технологічні та фінансові бар'єри для безпечного інтернет-зв'язку

Що це робить?

- Все ще з ключем, CSR, підтвердженням домену, отримати сертифікат
- Це автоматизовано
- Це безкоштовно



Як це працює

- Протокол ACME: <https://ietf-wg-acme.github.io/acme/>
- В основному визначає процес підтвердження домену
- Що нам потрібно знати: <https://letsencrypt.org/how-it-works/>
- Адміністратор сервера визначається парою ключів
- ЦС видає запити на авторизацію пари ключів, напр.
 - запис DNS
 - Файл на сервері

Підводні камені

Користувач, який запускає letsencrypt, повинен мати доступ для запису до кореневого веб-сервера

Переконайтеся, що дот-файли доступні

Шлях виклику: <https://my-domain.com/.well-known/acme-challenge/jd1o3ddZXTYbjwUHvRnQOECZToSY-BKxyd6LdFgJvOg>

```
server {  
    listen 80;  
  
    # don't do this  
    location ~ ^/\. {  
        deny all;  
    }  
}
```

Сертифікати

- Root CA: ISRG Root X1
- Проміжні продукти:
 - Let's Encrypt Authority X1 (ще не підтримується широко)
 - Let's Encrypt Authority X2 (відновлення)
- Хрест підписаний IdenTrust (DST Root CA X3), широко підтримується
- Видає сертифікати: <https://www.certificate-transparency.org>
- Можливість пошуку: <https://crt.sh/>

Підтримка клієнтів

Так:

- Android > 2.3.6
- Firefox > 2.0, Firefox OS > 2.2
- Windows: IE, Chrome
- Safari > 4.0, iOS > 3.1
- Linux: Debian > 6, Ubuntu > 12.04, CentOS ?
- Quickly tested:
- Node.js,
- PHP

Ні:

- Java as of jdk8u51 (applied for)
- Older Androids
- Windows XP
- Blackberry

Обмеження швидкості

Відповідно до <https://community.letsencrypt.org/t/rate-limits-for-lets-encrypt/6769>

- Домени на сертифікат: 100 Сертифікатів на домен: 5 certs/domain/week
- Реєстрації по IP: 500/3hrs
- Для тестування/розробки: використовуйте постановки env (--test-cert, --staging)
- Немає обмежень на загальну кількість сертифікатів

Інтеграції

- Інсталятор Apache (не пробував)
- Сервер Caddy
- Проміжне програмне забезпечення Express
- Повністю автоматизований SSL FTW!

Чому ви повинні це використовувати?

- Менше роботи - ти щасливий
- Це безкоштовно - ваш бос/клієнт щасливий
- Він зашифрований, що робить ваших користувачів безпечнішими
- Він автоматизований — робить людей DevOps щасливими



Certbot

Certbot

Certbot є частиною зусиль EFF із шифрування всього Інтернету. Безпечний зв'язок через Інтернет базується на протоколі HTTPS, який вимагає використання цифрового сертифіката, який дозволяє браузерам перевіряти ідентичність веб-серверів (наприклад, чи справді це google.com?). Веб-сервери отримують свої сертифікати від надійних третіх сторін, які називаються центрами сертифікації (ЦС). Certbot — це простий у використанні клієнт, який отримує сертифікат із Let's Encrypt — відкритого центру сертифікації, запущеного EFF, Mozilla та іншими — і розгортає його на веб-сервері.

Будь-хто, хто пройшов через проблеми з налаштуванням захищеного веб-сайту, знає, як важко отримати та підтримувати сертифікат. Certbot і Let's Encrypt можуть автоматизувати роботу та дозволити вам увімкнути HTTPS і керувати ним за допомогою простих команд. Використання Certbot і Let's Encrypt є безкоштовним, тому не потрібно вносити плату.

Certbot

Спосіб використання Certbot залежить від конфігурації веб-сервера. У більшості випадків для запуску Certbot вам потрібен доступ root або адміністратор до веб-сервера.

Certbot призначений для запуску безпосередньо на веб-сервері, а не на персональному комп'ютері. Якщо ви використовуєте розміщену службу та не маєте прямого доступу до свого веб-сервера, можливо, ви не зможете використовувати Certbot. Зверніться до свого хостинг-провайдера щодо документації щодо завантаження сертифікатів або використання сертифікатів, виданих Let's Encrypt.

Certbot — це повнофункціональний розширюваний клієнт для Let's Encrypt CA (або будь-якого іншого ЦС, який підтримує протокол ACME), який може автоматизувати завдання отримання сертифікатів і налаштування веб-серверів для їх використання. Цей клієнт працює на базі операційних систем Unix.

Як запустити клієнта

Найпростіший спосіб інсталювати та запустити Certbot — відвідати certbot.eff.org, де можна знайти правильні інструкції для багатьох комбінацій веб-сервера та ОС.

Certbot наразі потребує Python 2.7 або 3.6+, що працює в UNIX-подібній операційній системі. За замовчуванням для запису в `/etc/letsencrypt`, `/var/log/letsencrypt`, `/var/lib/letsencrypt` потрібен доступ `root`; для прив'язки до порту 80 (якщо ви використовуєте автономний плагін), а також для читання та зміни конфігурацій веб-сервера (якщо ви використовуєте плагіни `apache` або `nginx`). Якщо нічого з цього не стосується вас, теоретично можливо працювати без привілеїв `root`, але для більшості користувачів, які хочуть уникнути запуску клієнта ACME як `root`, `letsencrypt-nosudo` або `simp_le` є більш підходящим вибором.

Плагін `Apache` наразі вимагає ОС із `augeas` версії 1.0; наразі він підтримує сучасні ОС на основі `Debian`, `Ubuntu`, `Fedora`, `SUSE`, `Gentoo` та `Darwin`.

Більш глибоке розуміння клієнта

Щоб детально зрозуміти, що робить клієнт, важливо зрозуміти, як він використовує плагіни.

Plugin	Auth	Inst	Notes	Challenge types (and port)
apache	Y	Y	Automates obtaining and installing a certificate with Apache.	http-01 (80)
nginx	Y	Y	Automates obtaining and installing a certificate with Nginx.	http-01 (80)
webroot	Y	N	Obtains a certificate by writing to the webroot directory of an already running webserver.	http-01 (80)
standalone	Y	N	Uses a "standalone" webserver to obtain a certificate. Requires port 80 to be available. This is useful on systems with no webserver, or when direct integration with the local webserver is not supported or not desired.	http-01 (80)
DNS plugins	Y	N	This category of plugins automates obtaining a certificate by modifying DNS records to prove you have control over a domain. Doing domain validation in this way is the only way to obtain wildcard certificates from Let's Encrypt.	dns-01 (53)
manual	Y	N	Helps you obtain a certificate by giving you instructions to perform domain validation yourself. Additionally allows you to specify scripts to automate the validation task in a customized way.	http-01 (80) or dns-01 (53)

Питання та відповіді